

EGR6301 — Етичний хакінг

Практична робота 1: Правові основи, методологія пентесту та класифікація загроз

Тиждень 1

Орієнтовний час: 50 хвилин

Максимальний бал: 100

Потрібно: ручка/папір, друківана довідка PTES (надається), картка ATT&CK (надається)

Здача: рукописний або друкований PDF, формат: PW1_Прізвище_Група.pdf

Викладач:Тетяна Василівна Бабенко, д.т.н., професор

Цілі навчання

1. Класифікувати дії хакерів як етичні, grey-hat або злочинні на основі аналізу авторизації
2. Оцінити повноту документації авторизації тесту на проникнення
3. Відобразити реальні сценарії атак на фази PTES та тактики MITRE ATT&CK
4. Проаналізувати документ Score of Work для виявлення відсутніх елементів та правових ризиків
5. Сформулювати професійні рекомендації щодо документації pre-engagement
6. Застосувати правові знання (КК РК, CFAA, GDPR) до практичних сценаріїв

Вправа 1 — Класифікація інцидентів (30 балів — 6 балів за кожен)

Уважно прочитайте кожен сценарій. Для кожного визначте: (а) класифікацію дій особи (White Hat / Grey Hat / Black Hat / Не хакінг), (б) які закони або нормативні акти можуть застосовуватися, (с) що особа повинна була зробити інакше (якщо щось). Обґрунтуйте кожну відповідь 4–5 реченнями.

Сценарій А — Старанна практикантка

Айдана — літня практикантка у фінансовій компанії. Під час обіду вона помічає, що внутрішній HR-портал компанії має сторінку входу без HTTPS. З цікавості вона використовує Wireshark на своєму ноутбучі (підключеному до корпоративного Wi-Fi) для захоплення мережевого трафіку протягом 10 хвилин. Вона виявляє, що паролі співробітників передаються відкритим текстом. Пише звіт і надсилає його менеджеру IT-безпеки.

Класифікуйте дії Айдани. Чи була вона авторизована? Які документи зробили б це легітимним? Яка стаття КК РК може застосовуватися?

Сценарій Б — Студент університету

Бекзат вивчає курс етичного хакінгу. Він хоче попрактикувати сканування Nmap і вирішує просканувати публічний веб-сервер університету (university.edu.kz) зі свого гуртожитку, щоб «подивитись, що там є». Знаходить кілька відкритих портів та застаріле програмне забезпечення. Нічого не експлуатує, але зберігає результати сканування на ноутбучі.

Класифікуйте дії Бекзата. Чи надає статус студента кібербезпеки юридичний захист? Що він повинен був зробити замість цього?

Сценарій В — Консультант з безпеки

Дарія — сертифікований пентестер, найнята «KazTech Bank». Має підписаний контракт, Scope of Work (IP: 10.0.5.0/24), Rules of Engagement, NDA та Get Out of Jail лист. Під час тесту вона виявляє, що сервер 10.0.6.15 (поза її scope) має непатчену критичну вразливість, яка може розкрити 200 000 записів клієнтів.

Що повинна зробити Дарія? Чи може вона сканувати або тестувати 10.0.6.15? Який правильний професійний порядок дій?

Сценарій Г — Реагування на ransomware

Компанія наймає команду Ерлана для екстреного реагування на інцидент після атаки ransomware. Контракт вказує: «дослідити скомпрометований сервер 192.168.1.50.» Під час аналізу Ерлан виявляє, що ransomware також інфікував резервний сервер 192.168.1.51. CEO клієнта по телефону каже: «Перевірте і той теж, нам потрібно знати.»

Чи може Ерлан легально дослідити 192.168.1.51? Який конкретний документ потрібно оновити? Чому усна авторизація недостатня?

Сценарій Д — Мисливець за багами

Фатіма знаходить вразливість Cross-Site Scripting (XSS) на популярному інтернет-магазині. Сайт має публічну програму bug bounty на HackerOne з чітко визначеним scope: «*.shop.example.com — лише веб-застосунок». Вразливість XSS Фатіми знаходиться на admin.example.com, який НЕ вказаний у scope bug bounty.

Чи знаходиться знахідка Фатіми в авторизованому scope? Чи може вона подати її до програми bug bounty? Які ризики вона має? Яка різниця між scope bug bounty та фактичним доменом, який вона тестувала?

Вправа 2 — Аудит документів авторизації (25 балів)

Молодший пентестер підготував наступний Scope of Work для клієнтського завдання. Критично проаналізуйте його.

SCOPE OF WORK — Чернетка
Клієнт: «FastPay» — онлайн-платіжний сервіс
Тестувальник: PenTest Solutions LLC
Дата: Березень 2026

Scope: Тестування безпеки систем FastPay.
Цілі: Всі сервери FastPay.
Методи: Будь-які необхідні методи.
Термін: 2 тижні від підписання контракту.
Звітність: Результати будуть повідомлені клієнту.

Завдання 2.1 — Виявлення недоліків (10 балів)

Перерахуйте щонайменше CIM конкретних проблем у цьому Scope of Work. Для кожної проблеми поясніть, чому вона є небезпечною або непрофесійною. Врахуйте: конкретність цілей, обмеження методів, часові вікна, виключення, процедури ескалації, обробку даних та юридичні посилання.

Завдання 2.2 — Переписати SoW (10 балів)

Перепишіть цей Scope of Work як професійний документ. Включіть: конкретні IP-адреси або доменні імена (можете вигадати реалістичні), дозволені та заборонені методи тестування, графік тестування з конкретними датами та часовими вікнами, виключення, контакти для ескалації, вимоги щодо обробки даних та посилання на застосовні правові рамки.

Завдання 2.3 — Відсутні документи (5 балів)

Окрім Scope of Work, які ще три документи повинні бути підписані до початку цього завдання? Для кожного напишіть одне речення, що пояснює його зміст та чому він є необхідним.

Вправа 3 — Відображення фаз PTES (25 балів)

Команда тестування на проникнення проводить завдання для середньої компанії. Нижче наведено хронологію їхніх дій. Відобразіть кожну дію на відповідну фазу PTES.

Завдання 3.1 — Ідентифікація фаз (15 балів — 1,5 бали за кожне)

Відобразіть кожну дію на відповідну фазу PTES (Pre-engagement, Intelligence Gathering, Threat Modeling, Vulnerability Analysis, Exploitation, Post-Exploitation, Reporting). Напишіть назву фази поруч із кожною дією.

1. Команда підписує контракт та NDA з клієнтом. 2. Команда шукає в LinkedIn імена та ролі співробітників. 3. Команда запускає nmap -sV проти авторизованого діапазону IP. 4. Команда визначає, що Apache 2.2.8 має

відомі CVE. 5. Команда створює пріоритизований список векторів атаки. 6. Команда експлуатує backdoor vsftpd 2.3.4 для отримання shell. 7. Команда ескалує привілеї через SUID binary. 8. Команда документує всі знахідки з оцінками CVSS. 9. Команда виконує WHOIS-запит для цільового домену. 10. Команда пише executive summary для CEO.

Завдання 3.2 — Відображення ATT&CK (10 балів)

Наступна атака спостерігалась у реальному інциденті. Відобразіть кожен крок на правильну тактику MITRE ATT&CK та вкажіть ID техніки, якщо знаєте (частковий бал за правильну тактику без ID техніки).

Крок 1: Зловмисник надсилає spear-phishing лист CFO зі шкідливим вкладенням Excel. Тактика ATT&CK: _____ | Техніка: _____

Крок 2: Коли CFO відкриває файл, вбудований макрос виконує команду PowerShell. Тактика ATT&CK: _____ | Техніка: _____

Крок 3: Скрипт PowerShell завантажує Remote Access Trojan із зовнішнього сервера. Тактика ATT&CK: _____ | Техніка: _____

Крок 4: RAT додає себе до Windows Registry Run key для persistence. Тактика ATT&CK: _____ | Техніка: _____

Крок 5: Зловмисник використовує вкрадені облікові дані для доступу до файлового сервера через SMB. Тактика ATT&CK: _____ | Техніка: _____

Для повного балу вкажіть: назву тактики, назву техніки та T-номер (напр., T1566).

Вправа 4 — Професійна етика та відповідальність (20 балів)

Дайте відповіді з професійним обґрунтуванням. Кожна відповідь — 5–8 речень.

Завдання 4.1 — Етична дилема (10 балів)

Ви проводите авторизований тест на проникнення мережі лікарні. Скануючи авторизований сервер (у score), ви випадково виявляєте, що підключений медичний пристрій (НЕ в score) — контролер інфузійної помпи — доступний з обліковими даними за замовчуванням і не має автентифікації. Цей пристрій контролює дозування ліків для пацієнтів у реанімації.

Ви стоїте перед дилемою: вразливість критична та потенційно загрожує життю, але пристрій поза вашим авторизованим score.

Дайте відповідь: а) Який ваш негайний професійний обов'язок? б) До кого конкретно ви повинні звернутися і наскільки терміново? с) Чи можете ви тестувати або отримати доступ до інфузійної помпи для перевірки вразливості? Чому так чи ні? d) Як ви задокументуєте це у звіті? e) Яка етична основа керує вашим рішенням? (Посилайтесь на принципи responsible disclosure.)

Завдання 4.2 — Чому методологія важлива (10 балів)

Двом молодшим пентестерам призначена одна і та ж ціль. Їхні підходи відрізняються:

Тестувальник А: Завантажує Kali Linux, одразу запускає «msfconsole» і починає пробувати експлойти проти кожного відкритого порту. Через 3 години він отримав доступ до однієї системи, але не може пояснити, як і чому експлоїт спрацював. Нотаток немає.

Тестувальник Б: Уважно читає Score of Work, створює план тестування за фазами PTES, спочатку запускає nmap -sV, досліджує кожну виявлену версію сервісу, ідентифікує три потенційні вразливості з номерами CVE, обирає найперспективнішу, успішно експлуатує її, документує кожен крок і пише професійний звіт.

Обидва тестувальники знайшли одну й ту ж вразливість.

Дайте відповідь: а) Чий підхід є професійно прийнятним? Чому? б) Чому результати Тестувальника А будуть відхилені клієнтом, навіть якщо він знайшов реальну вразливість? с) Які конкретні ризики створює підхід Тестувальника А (юридичні, технічні, професійні)? d) Як дотримання методології PTES захищає тестувальника юридично та професійно? e) На співбесіді, кого б ви найняли? Обґрунтуйте.

Критерії оцінювання

Компонент	Бали	Критерії
Вправа 1 — Класифікація інцидентів	30	Правильна класифікація, юридичне обґрунтування, ідентифікація законів, якість аргументації

Вправа 2 — Аудит авторизації	25	Виявлення недоліків SoW, якість переписаного документа, знання необхідних документів
Вправа 3 — PTES та АТТ&СК	25	Правильне відображення фаз, ідентифікація технік АТТ&СК, розуміння послідовності
Вправа 4 — Етика та методологія	20	Глибина етичного обґрунтування, розуміння обов'язків, порівняння методологій
РАЗОМ	100	

Інструкції з подання

- ▶ Формат: рукописний (сканований у PDF) або друкований PDF
- ▶ Назва: PW1_Прізвище_Група.pdf (напр., PW1_Іванова_КБ401.pdf)
- ▶ Усі відповіді повинні містити обґрунтування — односкладні відповіді отримують нуль балів
- ▶ Можна використовувати слайди лекцій та надані довідки PTES/АТТ&СК
- ▶ Доступ до інтернету під час практичної роботи заборонений
- ▶ Подати через Teams до дедлайну